

แพลตฟอร์มปัญญาประดิษฐ์เพื่อสนับสนุนการปฏิบัติงานของศูนย์ปฏิบัติการ ความมั่นคงปลอดภัยไซเบอร์

VIGIX: AI-Powered SOC Automation Platform

บทคัดย่อ

บทความนี้นำเสนอ VIGIX ซึ่งเป็นแพลตฟอร์ม Security Orchestration, Automation and Response (SOAR) สำหรับสนับสนุนการจัดการเหตุการณ์ด้านความมั่นคงปลอดภัยไซเบอร์ ตั้งแต่การรับ Alert การสืบสวนและวิเคราะห์เหตุการณ์ การสร้างข้อเสนอแนะในการตอบสนอง (Recommendation) การตัดสินใจของผู้ปฏิบัติงาน Incident Response (IR) การตอบสนอง จนถึงการตรวจสอบผลด้วยการค้นหาซ้ำ (Re-hunt) ระบบรับ Alert จาก Wazuh และกำหนดระดับความรุนแรงจาก Wazuh Rule Level จากนั้นใช้แบบจำลองภาษาขนาดใหญ่ (LLM) ร่วมกับ MITRE ATT&CK และฐานความรู้ขององค์กรในการสร้าง Recommendation ซึ่งต้องผ่านการตรวจสอบขั้นตอนทำงาน 5 ขั้นตอน ได้แก่ การอ้างอิงหลักฐาน ความถูกต้องของ Action ความสอดคล้องของเป้าหมาย สิทธิ์ตามนโยบาย และความสอดคล้องกับ Playbook ก่อนส่งให้ IR พิจารณา โดยแบบจำลองภาษาไม่มีสิทธิ์อนุมัติหรือดำเนินการตอบสนอง การประเมินใช้กรณีทดสอบ 10 กรณีในสภาพแวดล้อมห้องปฏิบัติการ ด้วย Wazuh 4.9.2 บน Ubuntu endpoint และ Windows 10 endpoint ที่ติดตั้ง Sysmon สำหรับกรณี PowerShell โดยเปรียบเทียบกับ Ground Truth ที่กำหนดเป็นคู่ Action-Target ไว้ล่วงหน้า ผลการทดลองพบว่า Recommendation ตรงกับ Ground Truth ทั้งชุดภายใต้

เกณฑ์ strict exact-match จำนวน 4 จาก 10 กรณี (ร้อยละ 40.00) โดยกรณีที่ตรงส่วนใหญ่เป็นการเสนอ Action เพิ่มเติม นอกชุดอ้างอิง ขณะที่ Recommendation Compliance ผ่านทุกกรณีที่ประเมินได้ (9/9) ซึ่งวัดการปฏิบัติตามกฎของระบบ ไม่ใช่ความถูกต้องของคำแนะนำ และกรณี PowerShell ไม่มี Recommendation ที่ผ่านการตรวจสอบของระบบ Workflow Completion และ Verification/Re-hunt เท่ากับร้อยละ 70.00 (7/10) IOC Recall เท่ากับร้อยละ 91.30 (21/23) ค่าเฉลี่ย Investigation Time เท่ากับ 95.86 วินาที (9 กรณีที่มี Recommendation) และ Retry Rate กับ Intervention Rate เท่ากับร้อยละ 20.00 (2/10) การทดลองเสริมที่รายงานแยกพบว่า Core Recommendation Consistency จากการสร้างซ้ำ 15 ครั้งต่อกรณีเท่ากับร้อยละ 75.00 (33/44) กลไก Escalation เปลี่ยนสถานะเป็น ESCALATED เมื่อ Re-hunt ไม่สำเร็จครบ 3 รอบ และระบบไม่ดำเนินการตอบสนองเองเมื่อ IR ปฏิเสธ Recommendation ผลการทดลองได้จาก LLM หนึ่งแบบจำลอง การอนุมัติของ IR แบบสคริปต์ และสถานการณ์ที่ควบคุมในห้องปฏิบัติการ จึงยังไม่สามารถสรุปประสิทธิภาพในสภาพแวดล้อม SOC จริงได้ โดยความไม่ตรงกับ Ground Truth สัมพันธ์กับความสอดคล้องระหว่าง Playbook กับชุด Action อ้างอิง และความครอบคลุมของ Evidence และ IOC

คำสำคัญ –การประสานงานการทำงานอัตโนมัติและการตอบสนองด้านความมั่นคงปลอดภัย (SOAR), ศูนย์ปฏิบัติการความมั่นคงปลอดภัย, การทำงานร่วมกับมนุษย์, แบบจำลองภาษาขนาดใหญ่, การตอบสนองต่อเหตุการณ์, Wazuh

ABSTRACT

This paper presents VIGIX, an AI-powered SOC automation platform built on the security orchestration, automation, and response (SOAR) paradigm. VIGIX supports cybersecurity incident handling from alert ingestion, investigation, and analysis to response recommendation, incident response (IR) decision-making, and post-response verification through re-hunting. The system ingests alerts from Wazuh and derives severity from Wazuh rule levels. A large language model (LLM), combined with MITRE ATT&CK and an organizational knowledge base, generates response recommendations. Before submission to an IR analyst, each recommendation must pass five runtime checks covering evidence reference, action validity, target consistency, policy permission, and playbook alignment. The language model cannot approve or execute responses; all response decisions remain with the IR analyst. The evaluation used ten controlled test cases covering brute force, malware, phishing, account compromise, PowerShell, SQL injection, command and control, suspicious process execution, data exfiltration, and privilege escalation. Alerts were generated in a laboratory with Wazuh 4.9.2 on an Ubuntu endpoint and, for the PowerShell case, a Windows 10 endpoint with Sysmon, and recommendations were compared with action–target ground truth defined in advance. Under strict exact-match scoring, the recommendation matched the ground truth in 4 of 10 cases (40.00%); most mismatches were additional actions beyond the reference set. Recommendation compliance was 100%

(9/9) for the cases that produced a validated recommendation, which measures rule adherence rather than correctness; the PowerShell case produced none. Workflow completion and verification/re-hunting were both 70.00% (7/10), IOC recall was 91.30% (21/23), the mean investigation time was 95.86 s (nine cases with a recommendation), and the retry rate and intervention rate were both 20.00% (2/10). Supplementary experiments, reported separately, showed a core recommendation consistency of 75.00% (33/44) over 15 repeated generations per case on a fixed evidence snapshot, escalation after three unsuccessful re-hunt rounds, and no automatic execution after an IR rejection. The results come from one LLM, scripted IR approval, and controlled laboratory scenarios, and therefore do not establish effectiveness in a real SOC; the mismatches with the ground truth relate to the alignment between playbooks and the reference action sets and to the coverage of evidence and IOCs.

Keywords— Security orchestration, automation and response (SOAR); security operations center (SOC); human-in-the-loop; large language model; incident response; Wazuh

1. บทนำ

ปัจจุบันองค์กรต้องรับมือกับ SECURITY ALERT จำนวนมากจากระบบและอุปกรณ์ที่เชื่อมต่อกับเครือข่าย ส่งผลให้ SECURITY OPERATIONS CENTER (SOC) ต้องตรวจสอบและตอบสนองต่อเหตุการณ์ภายในเวลาที่จำกัด นักวิเคราะห์ความมั่นคงปลอดภัยต้องดำเนินการหลายขั้นตอน ตั้งแต่การคัดกรอง ALERT การรวบรวมและตรวจสอบ EVIDENCE การวิเคราะห์เหตุการณ์ การประเมินข้อมูลที่เกี่ยวข้อง และการกำหนดแนวทางตอบสนอง เมื่อมี ALERT เกิดขึ้นพร้อมกันหลายรายการภาระงานของนักวิเคราะห์เพิ่มขึ้น และอาจส่งผลกระทบต่อระยะเวลาและกระบวนการตัดสินใจเกี่ยวกับ INCIDENT [1], [5] ทั้งนี้ NIST SP 800-61 REV. 3 จัดการตอบสนองต่อเหตุการณ์เป็นส่วนหนึ่ง

ของการบริหารความเสี่ยงด้านความมั่นคงปลอดภัยไซเบอร์ [8] และแนวปฏิบัติด้านการจัดการเหตุการณ์ระบุการเตรียมความพร้อมและการระบุเหตุการณ์เบื้องต้นเป็นส่วนหนึ่งของการจัดการ INCIDENT [9]

การนำ ARTIFICIAL INTELLIGENCE (AI) และ LARGE LANGUAGE MODEL (LLM) มาใช้ในงาน SOC สามารถช่วยสนับสนุนการวิเคราะห์ข้อมูล การเพิ่มบริบทของ SECURITY EVENT และการสร้างแนวทางสำหรับ INCIDENT RESPONSE โดยมีการประยุกต์ใช้ร่วมกับแหล่งข้อมูลและเทคนิคต่าง ๆ เช่น RETRIEVAL-AUGMENTED GENERATION (RAG), CYBER THREAT INTELLIGENCE (CTI) และ MULTI-AGENT เพื่อสนับสนุนการวิเคราะห์และการตอบสนองต่อเหตุการณ์ [1], [3], [4] อย่างไรก็ตาม ผลลัพธ์จาก AI โดยเฉพาะ RESPONSE RECOMMENDATION ยังจำเป็นต้องได้รับการตรวจสอบก่อนนำไปใช้ เนื่องจากแนวทางการตอบสนองต้องสอดคล้องกับ POLICY และข้อกำหนดขององค์กร รวมถึงเงื่อนไขในการดำเนินการที่กำหนดไว้ [2]

นอกจากนี้ การนำ AI มาใช้ในกระบวนการ INCIDENT RESPONSE ควรคำนึงถึงบทบาทของผู้ปฏิบัติงาน โดยให้ AI ทำหน้าที่สนับสนุนการวิเคราะห์และเสนอ RECOMMENDATION ขณะที่ผู้ปฏิบัติงานยังคงมีส่วนร่วมในการตรวจสอบและตัดสินใจก่อนดำเนินการ RESPONSE แนวคิดดังกล่าวช่วยกำหนดขอบเขตการใช้งาน AI และลดการพึ่งพาการตัดสินใจจาก AI โดยตรง [5] อย่างไรก็ตาม การตรวจสอบและตัดสินใจก่อน RESPONSE เพียงอย่างเดียวยังไม่ครอบคลุมการตรวจสอบว่า RESPONSE ที่ดำเนินการแล้วสามารถจัดการกับเหตุการณ์ได้ตามที่คาดหวังหรือไม่

จากประเด็นดังกล่าว จึงมีช่องว่างในการเชื่อมโยงข้อมูลจากขั้นตอน INVESTIGATION เข้ากับ AI RECOMMENDATION การตรวจสอบตาม POLICY และ PLAYBOOK การตัดสินใจของผู้ปฏิบัติงาน การดำเนินการ RESPONSE และการตรวจสอบผลหลัง RESPONSE ให้เป็นกระบวนการเดียว โดยเฉพาะการนำ VERIFICATION และ RE-HUNT มาใช้ตรวจสอบสถานะของเหตุการณ์หลังการดำเนินการ และนำผลที่ได้กลับเข้าสู่กระบวนการ INVESTIGATION เมื่อจำเป็น

ดังนั้น การศึกษาและพัฒนาจึงนำเสนอ VIGIX: AI-POWERED SOC AUTOMATION PLATFORM เพื่อสนับสนุน

กระบวนการ SECURITY INCIDENT RESPONSE โดยใช้ WAZUH เป็นแหล่งข้อมูลหลัก และประยุกต์ใช้ LLM และ RAG เพื่อสนับสนุนการวิเคราะห์ EVIDENCE และสร้าง RESPONSE RECOMMENDATION ตามบริบทของ INCIDENT ระบบเชื่อมโยง RECOMMENDATION กับ POLICY และ PLAYBOOK และใช้ HUMAN-IN-THE-LOOP เพื่อให้ผู้ปฏิบัติงานตรวจสอบและตัดสินใจก่อนดำเนินการ RESPONSE โดยกำหนดให้ AI ทำหน้าที่เสนอ RECOMMENDATION และไม่ดำเนินการ RESPONSE ที่มีผลกระทบต่อระบบโดยอัตโนมัติ

หลังการดำเนินการ RESPONSE ระบบจะเข้าสู่ขั้นตอน VERIFICATION และ RE-HUNT เพื่อตรวจสอบผลของการ RESPONSE และตรวจสอบว่ายังพบเงื่อนไขหรือหลักฐานที่เกี่ยวข้องกับ INCIDENT หรือไม่ หากจำเป็น ผลการตรวจสอบสามารถนำกลับเข้าสู่กระบวนการ INVESTIGATION เพื่อประกอบการดำเนินงานต่อไป โดยระบบไม่ดำเนินการ RESPONSE ซ้ำโดยอัตโนมัติ

การศึกษาและพัฒนาที่ประเมินการทำงานของระบบตาม WORKFLOW ที่กำหนด โดยพิจารณา INVESTIGATION TIME, TIME-TO-DECISION, RECOMMENDATION COMPLIANCE, RECOMMENDATION CONSISTENCY และ NEGATIVE VALIDATION รวมถึงการทำงานของ HUMAN-IN-THE-LOOP การควบคุมสิทธิ์ และผลการตรวจสอบในขั้นตอน VERIFICATION และ RE-HUNT เพื่อประเมินความสามารถของระบบในการสนับสนุนกระบวนการ INCIDENT RESPONSE ตั้งแต่การวิเคราะห์เหตุการณ์จนถึงการตรวจสอบผลหลังการ RESPONSE WORKFLOW ที่กำหนด

2. ทฤษฎีและงานวิจัยที่เกี่ยวข้อง

งานวิจัยที่เกี่ยวข้องแบ่งเป็น 3 กลุ่ม ได้แก่ (1) การใช้ LLM ใน SOC และ Incident Response (2) การใช้ RAG และ CTI เพื่อสนับสนุนการวิเคราะห์ Security Event และ (3) การใช้ Policy Validation และ Human-in-the-Loop ในกระบวนการ

Incident Response โดยแต่ละกลุ่มมีแนวทางและข้อจำกัดที่แตกต่างกัน ซึ่งนำไปสู่แนวทางการออกแบบระบบ VIGIX

2.1 งานด้าน LLM สำหรับ SOC และ Incident Response

งานวิจัยกลุ่มนี้ นำ LLM และ Multi-Agent มาใช้สนับสนุนการวิเคราะห์ Security Alert และ Incident Response โดย Singh et al. ศึกษาการใช้งาน LLM ของ SOC Analyst และพบว่า LLM ถูกใช้เพื่อสนับสนุนการทำความเข้าใจเหตุการณ์และการวิเคราะห์ข้อมูลทางเทคนิค ขณะที่ Analyst ยังคงมีส่วนร่วมในการตรวจสอบและตัดสินใจ [5] Liu and Anwar ใช้ Multi-Agent ร่วมกับ RAG สำหรับ Incident Response Simulation [4] ส่วน Sheikhi et al. พัฒนา Multi-Agent LLM สำหรับ Triage และ Enrichment ของ Security Alert โดยเชื่อมโยงผลการวิเคราะห์กับหลักฐาน [6] นอกจากนี้ Rieger et al. ศึกษาการใช้ LLM ในการจำแนกและจัดลำดับความสำคัญของ Security Alert และพบว่าประสิทธิภาพด้าน Prioritisation มีข้อจำกัดมากกว่างาน Classification [7]

งานเหล่านี้แสดงให้เห็นว่า LLM สามารถสนับสนุนการวิเคราะห์ การ Triage การ Enrichment และการทำงานร่วมกับ Analyst ในงาน SOC ได้ อย่างไรก็ตาม แนวทางส่วนใหญ่มีขอบเขตอยู่ที่การสนับสนุนการวิเคราะห์หรือขั้นตอนเฉพาะของ Incident Response จึงยังมีประเด็นในการเชื่อมผลลัพธ์จาก AI เข้ากับกระบวนการ Response และการติดตามผลหลังการดำเนินการ

2.2 งานด้าน RAG และ CTI สำหรับ Security Event Analysis

งานวิจัยกลุ่มนี้มุ่งเพิ่มบริบทให้การวิเคราะห์ Security Event โดย Ismail et al. ใช้ Wazuh ร่วมกับ RAG และ LLM เพื่อวิเคราะห์ Security Event และสร้าง Response Guidance [1] ตารางที่ 2.4 เปรียบเทียบงานวิจัยที่เกี่ยวข้อง

ขณะที่ Tellache et al. ใช้ CTI, RAG และ LLM เพื่อเพิ่มบริบทของ Alert และสร้าง Mitigation Strategy [3] ส่วน Liu and Anwar ใช้ RAG เป็นแหล่งข้อมูลประกอบการทำงานของ Multi-Agent ใน Incident Response [4]

ผลการศึกษาดังกล่าวแสดงให้เห็นว่า RAG และ CTI สามารถเพิ่มข้อมูลประกอบการวิเคราะห์และช่วยสร้างแนวทาง Response ที่มีบริบทมากขึ้น อย่างไรก็ตาม งานเหล่านี้มุ่งเน้น Context Enrichment และการสร้าง Response Guidance หรือ Mitigation Strategy เป็นหลัก ขณะที่การเชื่อมข้อมูลดังกล่าวกับ Policy, Human Decision และการตรวจสอบผลหลัง Response ยังไม่ครอบคลุมในกระบวนการเดียว

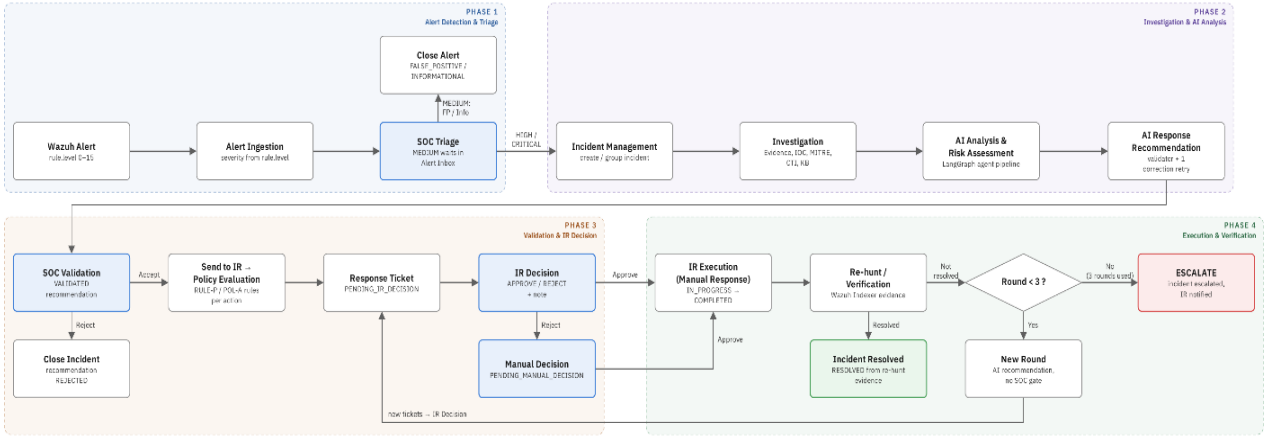
2.3 งานด้าน Policy Validation และ Human-in-the-Loop

งานวิจัยกลุ่มนี้มุ่งควบคุมและตรวจสอบผลลัพธ์จาก AI ก่อนนำไปใช้ใน Incident Response โดย Barbieri et al. พัฒนา SOCpilot ซึ่งใช้ Policy Verifier เพื่อตรวจสอบ Response Plan ที่สร้างโดย LLM ตาม Mandatory Steps, Ordering และ Approval Gates [2] ขณะที่ Singh et al. ศึกษาการทำงานร่วมกันระหว่าง LLM และ SOC Analyst โดย Analyst ยังคงมีส่วนร่วมในการตรวจสอบและตัดสินใจ [5]

งานดังกล่าวแสดงให้เห็นถึงความสำคัญของ Policy Validation และ Human-in-the-Loop ในการควบคุมผลลัพธ์จาก AI และสนับสนุนการตัดสินใจก่อนดำเนินการ Response อย่างไรก็ตาม แนวทางเหล่านี้มุ่งเน้นการตรวจสอบและการตัดสินใจก่อนดำเนินการเป็นหลัก จึงยังมีประเด็นในการเชื่อมกระบวนการดังกล่าวกับการดำเนินการ Response และการตรวจสอบผลหลัง Response ด้วย Verification และ Re-hunt

งานวิจัย	ระบบ / แนวทาง	Input / Scenario	วิธีการ	ผลลัพธ์หลัก	ข้อจำกัด / Research Gap
Ismail et al. [1]	Wazuh-RAG Copilot	Wazuh Security Event	Wazuh + RAG + LLM	Response Guidance	มุ่งเน้นการวิเคราะห์ Security Event และการสร้าง Response Guidance ไม่ได้เน้นการตรวจสอบ Policy และการตรวจสอบผลหลัง Response
Barbieri et al. [2]	SOCpilot	Incident / Response Plan	LLM + Policy Verifier	Policy Compliance และ Approval Gates	มุ่งเน้นการตรวจสอบ Response Plan ก่อนดำเนินการ ไม่ได้เน้นการตรวจสอบผลหลัง Response

Tellache et al. [3]	CTI + LLM	Alert + CTI	CTI + RAG + LLM	Context Enrichment และ Mitigation Strategy	มุ่งเน้นการเพิ่มบริบทและการสร้าง Mitigation Strategy ไม่ได้เน้นการตรวจสอบ Policy และการอนุมัติโดยผู้ปฏิบัติงาน
Liu & Anwar [4]	AutoBnB-RAG	Incident Response Simulation	Multi-Agent + RAG	Collaborative Incident Response	มุ่งเน้น Incident Response Simulation และการทำงานร่วมกันของ Multi-Agent ไม่ได้เน้นการเชื่อมโยง Policy Validation และ Human Decision เข้ากับกระบวนการ Response และ Verification แบบครบวงจร
Singh et al. [5]	LLMs in the SOC	SOC Analyst Queries	Human-AI Collaboration	สนับสนุนการวิเคราะห์ของ SOC Analyst	มุ่งเน้นการทำงานร่วมกันระหว่าง LLM และ Analyst มากกว่าการพัฒนากระบวนการ Incident Response แบบ End-to-End
VIGIX	AI-assisted SOC Platform	Alert + Evidence + Knowledge	Wazuh + AI/RAG + Policy/HITL	AI Recommendation → Response → Verification	เชื่อมโยงกระบวนการข้างต้นเป็น Workflow เดียว โดยจำกัดขอบเขต Response ที่การกักกันเหตุการณ์ในระยะสั้น (Short-Term Containment)



ภาพที่3.1: VIGIX Main Workflow — SOC Triage, AI Response Recommendation, and Incident Response Loop

3. วิธีการดำเนินงาน

การศึกษาและพัฒนาที่ใช้ระเบียบวิธีวิจัยเชิงออกแบบและ พัฒนา (Design and Development Research) ในการพัฒนาระบบ VIGIX ให้เป็นแพลตฟอร์ม SOAR (Security Orchestration, Automation and Response) ที่กำหนดให้มนุษย์เป็นผู้ตัดสินใจก่อนการตอบสนองทุกครั้ง

3.1 ภาพรวมของ Workflow

VIGIX แบ่งการทำงานออกเป็น 4 ระยะต่อเนื่องกัน ดังภาพที่ 3.1

1. Alert and Incident Management

รับ Security Alert จาก Wazuh ประเมิน Severity และพิจารณาสร้าง Incident

2. Investigation and AI Recommendation

รวบรวมหลักฐานและข้อมูลที่เกี่ยวข้อง ประมวลผลผ่านกระบวนการ RAG เพื่อสร้าง Recommendation

3. Response and Human Decision

ผู้ปฏิบัติงาน (IR) ตัดสินใจ Accept หรือ Reject Recommendation ก่อนดำเนินการ Response

4. Verification and Re-hunt

ตรวจสอบผลลัพธ์หลังการ Response และค้นหาเหตุการณ์ซ้ำก่อนปิด Incident

ลำดับการทำงานทั้งหมดควบคุมโดย AI Orchestrator ที่พัฒนาด้วย LangGraph ในรูปแบบ State-based Workflow โดยสถานะถัดไปของ Incident ขึ้นกับสถานะปัจจุบันและข้อมูลนำเข้า ดังสมการที่ (1)

$$S_{t+1} = F(S_t, I_t) \quad (1)$$

โดยที่ S_t คือสถานะของกระบวนการ ณ เวลา

t , I_t คือข้อมูลนำเข้า และ F คือฟังก์ชันที่กำหนดการประมวลผลและสถานะถัดไป

เพื่ออธิบายลำดับการทำงานของระบบโดยรวม สามารถสรุปเป็น Algorithm 1 ดังนี้

Algorithm 1 : VIGIX Incident Response Workflow

```

Input: security alert a from Wazuh, maximum
re-hunt rounds R_max = 3,
validation set V = {V_E, V_A, V_T,
V_P, V_PB}
Output: final incident status S
1: Receive alert a and collect related
information
2: sev ← InitialSeverity(a.rule_level)
3: E ← ExamineEvidence(a)
4: if not CreateIncident(a, E, sev) then
5: return NO_INCIDENT
6: terminate alert processing
7: end if
8: Create incident I; r ← 0
9: while true do
10: C ← Aggregate(alerts, E, IOC, TI,
MITRE ATT&CK, KB)
11: K ← RAG_Retrieve(C)
12: p ← GenerateRecommendation(C, K)
13: if not (V_E(p) ∧ V_A(p) ∧ V_T(p) ∧
V_P(p) ∧ V_PB(p)) then
14: Record validation result; do not
execute p
15: if attempts remain then
16: regenerate p (go to line 11) else return
OPEN
17: no response executed; incident
remains open
18: else
19: Submit p to IR for review
20: if IR approves p then
21: Create response ticket T
22: action ← ExecuteResponse(T,
p)
23: else
24: Do not execute p; do not
auto-generate a new p
25: action ← ManualResponse_IR(I)
26: record rationale and outcome
27: end if
28: end if
29: v ← Verify(I, action)
30: if v ∈ {RESOLVED, NOT_RESOLVED,
SPREAD, NOT_CONTAINED}
31: if v = RESOLVED then
32: return RESOLVED
33: close incident
34: end if
35: r ← r + 1
36: if r ≥ R_max then
37: S ← ESCALATED

```

```

33: return S
34: terminate automated process
35: end if
36: E ← E ∪ ReHunt(I)
37: feed results back into investigation
38: end while

```

3.2 ระยะที่ 1 : Alert and Incident Management

VIGIX รับ Security Alert จาก Wazuh เป็นข้อมูลนำเข้าสำหรับการจัดการ Incident โดยข้อมูลที่นำมาใช้ประกอบการตรวจสอบ ได้แก่ Rule ID, Rule Level, Agent ID, Timestamp, Source IP, Destination IP, IOC และ Event Data ระบบใช้ Wazuh Rule Level เป็นค่าเริ่มต้นในการกำหนด Severity โดยไม่ให้ AI กำหนดหรือเปลี่ยนแปลง Severity ตามสมการที่ (2)

$$Severity_{initial} = f(RuleLevel_{wazuh}) \quad (2)$$

โดย (f) คือฟังก์ชันที่ใช้แปลงข้อมูล Rule Level เป็น Severity ตามการกำหนดของระบบ

จากนั้นระบบพิจารณาการสร้าง Incident โดยใช้ Severity เป็นเงื่อนไขเริ่มต้นตามสมการที่ (3)

$$Incident = \begin{cases} 1, & Severity_{final} \in S_{incident} \\ 0, & otherwise \end{cases} \quad (3)$$

ในการประเมินระบบได้กำหนด Security Alert จำนวน 10 ประเภท ได้แก่ Brute Force, Malware, Phishing, Account Compromise, PowerShell, SQL Injection, Command and Control (C2), Suspicious Process Execution, Data Exfiltration และ Privilege Escalation เพื่อใช้ทดสอบความสามารถของระบบในกระบวนการ Alert และ Incident Management

3.3 ระยะที่ 2 : Investigation and AI Recommendation

เมื่อสร้าง Incident แล้ว ระบบจะรวบรวมข้อมูลที่เกี่ยวข้องกับเหตุการณ์เพื่อใช้ในการ Investigation ได้แก่ Alert, Evidence, IOC, Threat Intelligence (TI), MITRE ATT&CK และ Knowledge Base ซึ่งประกอบด้วย Policy, Playbook, Runbook และ Action

ระบบนำข้อมูลเข้าสู่กระบวนการ Retrieval-Augmented Generation (RAG) โดยสร้าง Embedding และค้นหาข้อมูลที่เกี่ยวข้องจาก Qdrant จากนั้นเชื่อมผลการค้นหากับรายละเอียด

ของ Policy, Playbook, Runbook และ Action ที่จัดเก็บผ่าน Prisma เพื่อใช้เป็นบริบทในการสร้าง Recommendation Recommendation ที่สร้างขึ้นประกอบด้วย Action, Target, Reason และ Evidence ตามสมการที่ (4)

$$Recommendation = (Action, Target, Reason, Evidence) \quad (4)$$

โดย Action คือแนวทางการตอบสนองที่ระบบเสนอ, Target คือเป้าหมายของการดำเนินการ, Reason คือเหตุผลที่สนับสนุน Recommendation และ Evidence คือหลักฐานที่ใช้ประกอบการวิเคราะห์

ก่อนส่ง Recommendation ให้ IR ระบบดำเนินการ Backend Validation จำนวน 5 เงื่อนไข ได้แก่ (V_E) ตรวจสอบว่า Recommendation อ้างอิง Evidence ที่มีอยู่จริงใน Incident, (V_A) ตรวจสอบว่า Action อยู่ในรายการ Action ที่ระบบรองรับ, (V_T) ตรวจสอบว่า Target สอดคล้องกับข้อมูลใน Evidence, (V_P) ตรวจสอบว่า Action ได้รับอนุญาตตาม Policy และ (V_{PB}) ตรวจสอบว่า Action สอดคล้องกับ Playbook ของเหตุการณ์ประเภทนั้น โดยเงื่อนไขทั้งหมดแสดงในสมการที่ (5)

$$V = (V_E, V_A, V_T, V_P, V_{PB}) \quad (5)$$

และ (6)

$$V_i = \begin{cases} 1, & \text{pass} \\ 0, & \text{fail} \end{cases}, i \in \{E, A, T, P, PB\} \quad (6)$$

Recommendation จะผ่าน Validation ก็ต่อเมื่อเงื่อนไขทั้ง 5 ข้อผ่านทั้งหมด หากมีเงื่อนไขใดไม่ผ่าน ระบบจะบันทึกผลการ Validation และไม่ดำเนินการ Response ตาม Recommendation ดังกล่าว และสร้าง Recommendation ใหม่ภายในจำนวนครั้งที่จำกัด หากยังไม่ได้ Recommendation ที่ผ่านการตรวจสอบ Incident จะคงสถานะเปิดโดยไม่มีการดำเนินการ Response ใด ๆ ส่วน Recommendation ที่ผ่าน Validation จะถูกส่งต่อไปยังขั้นตอน Human Decision

3.4 ระยะที่3 : Response and Human Decision

Recommendation ที่ผ่าน Backend Validation จะถูกส่งให้ IR ตรวจสอบ โดย AI ไม่มีสิทธิ์อนุมัติหรือดำเนินการ Response โดยตรง IR เป็นผู้ตัดสินใจ Approve หรือ Reject ตามสมการที่ (7)

$$Decision \in \{APPROVE, REJECT\} \quad (7)$$

กรณี APPROVE ระบบจะสร้าง Response Ticket ตาม Action และ Target ที่ผ่านการตรวจสอบ และดำเนินการตามกระบวนการ Response ที่กำหนดไว้ โดยการดำเนินการ Response ต้องอยู่ภายใต้การตัดสินใจของ IR และระบบไม่อนุญาตให้ AI ดำเนินการ Response ที่มีผลกระทบต่อระบบโดยตรง

กรณี REJECT ระบบจะไม่ดำเนินการตาม Recommendation และจะไม่ปิด Incident หรือสร้าง Recommendation ใหม่โดยอัตโนมัติจากการ Reject ดังกล่าว IR สามารถดำเนินการ Manual Decision หรือ Manual Response ตามสถานการณ์และบันทึกเหตุผลและผลการดำเนินการ จากนั้น Incident จะเข้าสู่ขั้นตอน Verification เช่นเดียวกับกรณีที่มีการดำเนินการ Response

ข้อมูลที่เกี่ยวข้องกับ Human-in-the-Loop และ Response จะถูกบันทึกเป็น Audit Data ได้แก่ Incident ID, Recommendation ID, Action, Target, IR Decision, Decision Note, Response Status, Response Result และ Timestamp รวมถึงข้อมูลการปรับ Severity หากมีการปรับโดย SOC

3.5 ระยะที่4 : Verification and Re-hunt

หลังการดำเนินการ Response ระบบนำ IOC และเงื่อนไขที่เกี่ยวข้องกับ Incident ไปค้นหาเหตุการณ์ใน Wazuh อีกครั้ง ภายใต้ขอบเขตและช่วงเวลาที่กำหนด ผลการตรวจสอบแบ่งเป็น 4 สถานะ ได้แก่ RESOLVED, NOT_RESOLVED, SPREAD และ NOT_CONTAINED ตามสมการที่ (8)

$$VerificationResult \in \{RESOLVED, NOT_RESOLVED, SPREAD, NOT_CONTAINED\} \quad (8)$$

หากผลการตรวจสอบไม่เป็น RESOLVED ระบบจะเพิ่มจำนวนรอบ Re-hunt และนำผลการค้นหากลับเข้าสู่กระบวนการ Investigation เพื่อใช้เป็นข้อมูลประกอบการวิเคราะห์ในรอบถัดไป โดยกำหนดจำนวนรอบ Re-hunt สูงสุด ($R_{max} = 3$) การกำหนดสถานะถัดไปของ Incident แสดงดังสมการ (9)

$$NextState = \begin{cases} CLOSED, & VerificationResult = RESOLVED \\ REHUNT, & VerificationResult \neq RESOLVED \wedge r < R_{max} \\ ESCALATED, & VerificationResult \neq RESOLVED \wedge r \geq R_{max} \end{cases} \quad (9)$$

โดย r คือจำนวนรอบ Re-hunt ที่ดำเนินการแล้ว และ R_{max} คือจำนวนรอบสูงสุดที่กำหนดไว้ในระบบ เมื่อผล Verification เป็น RESOLVED ระบบจะปิด Incident เมื่อยังไม่สามารถยืนยันการแก้ไขได้และจำนวนรอบยังไม่ถึงขีดจำกัด ระบบจะเข้าสู่ Re-

hunt เพื่อรวบรวมข้อมูลเพิ่มเติม ส่วนกรณีที่ครบจำนวนรอบสูงสุดแล้วยังไม่เป็น RESOLVED ระบบจะกำหนดสถานะเป็น ESCALATED และสิ้นสุดกระบวนการอัตโนมัติ โดยให้ผู้ปฏิบัติงานดำเนินการต่อในลักษณะ Manual ตามความเหมาะสม

4. ผลการทดลองและอภิปรายผล

การประเมินระบบ VIGIX (Final Evaluation v3.3, run ID final-evaluation-v3.3, source commit 245b536) ดำเนินการในสภาพแวดล้อมห้องปฏิบัติการด้วย Wazuh 4.9.2 โดยใช้ Wazuh agent บน Ubuntu endpoint และ Windows 10 endpoint ที่ติดตั้ง Sysmon 15.22 สำหรับกรณี PowerShell เพื่อสร้างและรวบรวม Security Alert จากสถานการณ์โจมตีที่ควบคุมไว้จำนวน 10 กรณี กรณี TC-01, TC-04 และ TC-06 ใช้กฎมาตรฐานของ Wazuh ส่วนกรณีอื่นใช้กฎที่พัฒนาเพิ่ม (custom rule) ร่วมกับกิจกรรมจริงบน endpoint (TC-02, TC-05, TC-10) หรือ telemetry ที่ควบคุม (TC-03, TC-07, TC-08, TC-09) ทั้ง 10 กรณีรันใน run เดียวกัน Alert ที่ได้ถูกส่งเข้าสู่ Workflow ของ VIGIX ตั้งแต่ Alert Ingestion, Incident, Investigation, Recommendation, การตัดสินใจของ Incident Response (IR), Response จนถึง Verification/Re-hunt บน Wazuh หลักฐานการทดลอง (run.json ผลรายการณ์ บันทึกการตรวจสอบ และค่า hash ของ Ground Truth) จัดเก็บในที่เก็บ GitHub ของโครงการ (<https://github.com/kanokniphpanset/VIGIX-AI-Powered-SOC-Automation-Platform>, source commit 245b536 และไฟล์เดอร์ results/runs)

การทดลองใช้แบบจำลองภาษาขนาดใหญ่ (LLM) จำนวน 1 แบบจำลอง คือ vllm-spark-01/gemma4-26b-uncensored ซึ่งเป็น AI Server ของบริษัทและใช้การอนุมัติแบบสคริปต์ (Scripted Approval) ในขั้นตอนการตัดสินใจของ IR ผลในส่วนการตัดสินใจจึงใช้ตรวจสอบกลไก Human-in-the-Loop และการบันทึกกระบวนการ ไม่ใช้การวัดเวลาที่ผู้ปฏิบัติงานจริงใช้ในการพิจารณา

แต่ละกรณีมีการกำหนดผลอ้างอิง (Ground Truth) สำหรับ Recommendation, IOC และผล Verification/Re-hunt โดย Ground Truth ของ Recommendation กำหนดเป็นชุดคู่

Action–Target ที่คาดหวังของแต่ละกรณี (ไม่มีคู่ที่เป็นทางเลือก) ใช้เวอร์ชัน correctness-gt-v3.3 ตรึงด้วยค่า SHA-256 d2f1dae6...5951a8 (Ground Truth ของ IOC และ Workflow ตรึงด้วย SHA-256 9a800bab...69f6de) ผู้กำหนดคือผู้พัฒนาระบบโดยใช้กฎที่ระบุไว้ล่วงหน้า คือจับคู่ Action ที่ Ground Truth ระบุกับเป้าหมายที่มีชนิดตรงกับ Action Catalog และเพิ่มขั้นตอนมาตรฐานของ Playbook ที่เป็น unconditional บางขั้น ทั้งนี้ Ground Truth รุ่น v3.1–v3.3 ถูกปรับหลังจากเห็นผลการทดลองรุ่นก่อนหน้าแล้ว การทดลองใน v3.3 จึงเป็นการรันแรกภายใต้ Ground Truth ที่ตรึงไว้ แต่ไม่ใช้การประเมินแบบ blind และยังไม่มีผู้เชี่ยวชาญอิสระตรวจสอบ Ground Truth ในตารางที่ 4.1 สถานะ Workflow "ครบ" หมายถึงดำเนินการได้ถึง Verification/Re-hunt และ "ไม่ครบ" หมายถึงดำเนินการได้เพียงบางส่วนเนื่องจากข้อจำกัดด้าน Evidence เงื่อนไข Re-hunt หรือการสร้าง Recommendation ส่วนความตรงกับ Ground Truth ของ Recommendation แสดงแยกเป็น "ตรง GT" หรือ "ไม่ตรง GT"

ตารางที่ 4.1 กรณีทดสอบ(Experimental Cases)

Case	Attack Scenario	สถานะ (Workflow / C o r r e c t Recommendation)
TC-01	Brute Force (กฎมาตรฐาน)	ครบ / ตรง GT
TC-02	Malware (custom rule + กิจกรรมจริง)	ไม่ครบ / ไม่ตรง GT (ขาด Action)
TC-03	Phishing (custom rule + telemetry ควบคุม)	ครบ / ตรง GT
TC-04	Account Compromise (กฎมาตรฐาน)	ครบ / ไม่ตรง GT (Action เกิน)
TC-05	PowerShell (custom rule + กิจกรรมจริงบน Windows)	ไม่ ครบ / ไม่ มี Recommendation
TC-06	SQL Injection (กฎมาตรฐาน)	ครบ / ตรง GT
TC-07	Command & Control (custom rule + telemetry ควบคุม)	ครบ / ไม่ตรง GT (Action เกิน)
TC-08	Suspicious Process Execution (custom rule + telemetry ควบคุม)	ครบ / ตรง GT
TC-09	Data Exfiltration (custom rule + telemetry ควบคุม)	ครบ / ไม่ตรง GT (Action เกิน)
TC-10	Privilege Escalation (custom rule + กิจกรรมจริง)	ไม่ครบ / ไม่ตรง GT (Action เกิน)

TC-05 ประเมินบน Windows 10 endpoint ที่ติดตั้ง Wazuh agent และ Sysmon 15.22 โดยกฎ 100300 ตรวจจับ DNS query ของ powershell.exe (Sysmon Event 22) และผู้ทดลองเป็นผู้กระตุ้นกิจกรรมดังกล่าว ผลคือระบบไม่สามารถสร้าง Recommendation ที่ผ่านการตรวจสอบได้ จึงนับเป็นหนึ่งกรณีในตัวหารของตัวชี้วัดหลัก ทำให้จำนวนกรณีที่ประเมินเท่ากับ 10 กรณี ดังสมการที่ (10)

$$N_{evaluated} = 10 \quad (10)$$

4.2 ตัวชี้วัด

ตัวชี้วัดครอบคลุมความถูกต้องและความสอดคล้องของ Recommendation ความสมบูรณ์ของ Workflow การสกัด IOC ระยะเวลาการทำงาน และการควบคุม Human-in-the-Loop โดยใช้จำนวนกรณีทดสอบดังสมการที่ (10) เป็นตัวหารหลัก ยกเว้น Recommendation Compliance ซึ่งใช้เฉพาะกรณีที่มี Recommendation ที่ผ่านการตรวจสอบ ($N_{rec} = 9$) และ Investigation Time ซึ่งคำนวณจาก 9 กรณีที่มี Recommendation ส่วน Consistency, Escalation และการปฏิเสธโดย IR เป็นการทดลองเสริมที่รายงานแยกจากตัวชี้วัดหลัก

4.2.1 Recommendation Compliance

กำหนดสถานะของกรณีที่ i ดังสมการ(11)

$$Compliant_i = \begin{cases} 1, & \text{เมื่อผ่านเกณฑ์ครบทั้ง 7 ด้าน} \\ 0, & \text{เมื่อไม่ผ่านอย่างน้อย 1 ด้าน} \end{cases} \quad (11)$$

เกณฑ์ทั้ง 7 ด้าน ได้แก่ attackAlignment, evidenceSupport, knowledgeValidity, policyCompliance, playbookAlignment, approvalCorrectness และ targetRole โดยเงื่อนไขขณะทำงาน V_E, V_A, V_T, V_P และ V_{PB} สอดคล้องโดยประมาณกับเกณฑ์ evidenceSupport, knowledgeValidity, evidenceSupport, policyCompliance และ playbookAlignment ตามลำดับ ส่วน attackAlignment, approvalCorrectness และ targetRole เป็นเกณฑ์ประเมินเพิ่มเติมที่ตรวจหลังการทดลอง (attackAlignment และการเทียบ Playbook ที่คาดหวังของ playbookAlignment ใช้ Ground Truth)

$$RC = \frac{\sum_{i=1}^{N_{rec}} Compliant_i}{N_{rec}} \times 100 \quad (12)$$

ใน 9 กรณีที่มี Recommendation ที่ผ่านการตรวจสอบ ($N_{rec} = 9$) ผ่านครบทุกเกณฑ์ จึงได้ $RC = \frac{9}{9} \times 100 = 100\%$ คำนี้นับว่า Recommendation ฉบับสุดท้ายที่ผ่านการตรวจสอบแล้วสอดคล้องกับกฎของระบบและหลักฐานของ Incident หรือไม่ใช่ค่าความแม่นยำของแบบจำลอง และไม่ได้หมายความว่า Recommendation ตรงกับ Ground Truth (Correct Recommendation อยู่ที่ 4 จาก 10 กรณี หรือร้อยละ 40.00 ดังหัวข้อ 4.2.2) นอกจากนี้ Compliance วัดจาก Recommendation ฉบับสุดท้ายที่ผ่านการตรวจสอบของแต่ละกรณี ไม่ใช่ผลของการสร้างทุกครั้ง เมื่อนับทุกครั้งที่เรียกสร้าง ระบบเรียกสร้าง Recommendation ทั้งหมด 16 ครั้ง และผ่านการตรวจสอบในครั้งแรก 8 จาก 10 กรณี (ร้อยละ 80.00) โดย TC-03 ผ่านในครั้งที่ 3 และ TC-05 ไม่ผ่านทั้ง 5 ครั้ง

4.2.2 Correct Recommendation (ตัวชี้วัดหลัก)

Correct Recommendation วัดว่า Recommendation ฉบับสุดท้ายของแต่ละกรณีตรงกับ Ground Truth หรือไม่ โดยเปรียบเทียบเซตของคู่ Action-Target แบบ strict exact-match (ไม่สนลำดับ เปรียบเทียบหลัง trim และ lowercase คู่ซ้ำนับครั้งเดียว และไม่มีคู่ที่เป็นทางเลือก) กรณีที่ i ถือว่าถูกต้องเมื่อ Playbook ตรง มีคู่ Action-Target ที่ Ground Truth กำหนดครบทุกคู่ และไม่มีคู่ที่นอกเหนือจาก Ground Truth ดังนี้

$$Correct_i = PlaybookMatch_i \wedge ActionTargetMatch_i \wedge NoUnexpectedAction_i$$

$$CR = (\sum Correct_i / N_{evaluated}) \times 100 = (4 / 10) \times 100 = 40.00\%$$

กรณีที่ไม่มี Recommendation ที่ผ่านการตรวจสอบ (TC-05) ถือว่าไม่ตรง Ground Truth และยังนับในตัวหาร ผลคือตรง 4 กรณี (TC-01, TC-03, TC-06 และ TC-08) และไม่ตรง 6 กรณี ได้แก่ TC-04, TC-07, TC-09 และ TC-10 ซึ่งมี Action ที่จำเป็นครบแต่เสนอ Action เพิ่มเติมนอกชุด Ground Truth, TC-02 ซึ่งขาด Action ที่จำเป็น (QUARANTINE-FILE และ BLOCK-HASH) และ TC-05 ซึ่งไม่มี Recommendation คำนี้นอกจาก Recommendation Compliance: Correct

Recommendation วัดความตรงกับ Ground Truth ส่วน Compliance วัดการผ่านกฎของระบบ และไม่ควรวัดความเป็นค่าความแม่นยำของแบบจำลองโดยรวม เนื่องจากขึ้นกับการกำหนดชุด Action อ้างอิง (ดูหัวข้อ 4.5)

4.2.3 Core Recommendation Consistency (การทดลองเสริม)

Core Recommendation Consistency วัดจากการสร้าง Recommendation ขึ้นบนหลักฐานชุดเดิมของแต่ละกรณี (ไม่ยิง Attack ใหม่) โดยสร้างลายเซ็นมาตรฐานของ Recommendation เป็นเซตของคู่ Action::Target (ไม่สนลำดับ trim และ lowercase คู่ซ้ำนับครั้งเดียว) แล้วนับจำนวนรอบที่ ตรงกับลายเซ็นที่พบบ่อยที่สุดต่อรอบที่สร้าง Recommendation ได้สำเร็จ ดังสมการที่ (13)

$$RCons = \frac{N_{consistent}}{N_{valid}} \times 100 \quad (13)$$

ทดสอบซ้ำ 3 กรณี (TC-03, TC-08 และ TC-10) กรณีละ 15 รอบ รวม 45 รอบ สร้าง Recommendation ที่ผ่านการตรวจสอบได้ 44 รอบ (Generation Success 44/45 = 97.78% รอบที่ไม่ผ่านคือ TC-08 หนึ่งรอบ) $N_{valid} = 44$ รอบ โดยมี 33 รอบที่ ตรงกับลายเซ็นที่พบบ่อยที่สุด จึงได้ $RCons = \frac{33}{44} \times 100 = 75.00\%$

ผลแยกตามกรณีคือ TC-03 12/15 (80.00%), TC-08 13/14 (92.86%) และ TC-10 8/15 (53.33%) ความแปรผันที่พบเกิดจากการเติม Action เพิ่มเติมจากชุดหลัก (ISOLATE-ENDPOINT, RESET-CREDENTIAL) ไม่พบการเปลี่ยน Target หรือ Playbook (Target Consistency 128/128 = 100%, Playbook Consistency 44/44 = 100%) เกณฑ์นี้เข้มงวดกว่านิยามที่นับเฉพาะ Action แรก ซึ่งให้ค่าสูงกว่า Core Consistency วัดความซ้ำได้ ไม่ใช่ความถูกต้อง และไม่ควรรนำไปเฉลี่ยกับ Correct Recommendation

4.2.4 Workflow Completion

$$WC = \frac{N_{completed}}{N_{evaluated}} \times 100 \quad (14)$$

มี 7 กรณีจากทั้งหมด 10 กรณีที่ดำเนินการครบตาม Workflow จึงได้ $WC = \frac{7}{10} \times 100 = 70.00\%$ ส่วน TC-02 และ TC-10 ไม่สามารถสร้างเงื่อนไข Re-hunt จาก IOC ที่สกัดได้ และ TC-05 ไม่มี Recommendation ที่ผ่านการตรวจสอบ

4.2.5 Verification/Re-hunt

$$VR = \frac{N_{resolved}}{N_{evaluated}} \times 100 \quad (15)$$

มี 7 กรณีที่ค้นหาซ้ำบน Wazuh แล้วได้สถานะ RESOLVED จึงได้ $VR = \frac{7}{10} \times 100 = 70.00\%$

สถานะ RESOLVED หมายถึงไม่พบเหตุการณ์ที่เกี่ยวข้องภายในขอบเขตและเวลาที่กำหนด ไม่ใช่การยืนยันว่าภัยคุกคามถูกกำจัดหมดแล้ว ส่วน TC-02 และ TC-10 ได้ผล REHUNT_INSUFFICIENT_CRITERIA ซึ่งหมายถึงข้อมูลไม่เพียงพอสำหรับสร้างเงื่อนไขค้นหาซ้ำ และไม่ควรวัดความเป็น NOT_RESOLVED

4.2.6 IOC Recall

$$Recall_{IOC} = \frac{N_{IOC\ extracted}}{N_{IOC\ expected}} \times 100 \quad (16)$$

IOC ที่สกัดได้ก่อนการแก้ไขโดย Analyst จาก 10 กรณีเท่ากับ $2+0+4+2+1+1+3+4+3+1 = 21$ รายการ จาก IOC ที่คาดหวัง $2+2+4+2+1+1+3+4+3+1 = 23$ รายการ ซึ่งกำหนดไว้ล่วงหน้าใน Ground Truth โดยผู้พัฒนาและนับเฉพาะ IOC ที่ปรากฏใน Alert ของ Wazuh จึงได้

$$Recall_{IOC} = \frac{21}{23} \times 100 = 91.30\%$$

IOC ที่ขาดไปทั้ง 2 รายการอยู่ใน TC-02 โดย Hash และ File Path อยู่ในไฟล์ syscheck.* ขณะที่ตัวสกัด IOC อ่านจาก data.* เป็นหลัก

4.2.7 Investigation Time

$$T_{investigation} = T_{recommendation} - T_{investigation\ start} \quad (17)$$

$$\bar{T}_{investigation} = \frac{1}{n} \sum_{i=1}^n T_{investigation,i} \quad (18)$$

เวลารวมของ 9 กรณี (TC-05 ไม่มีค่าเนื่องจากไม่มี Recommendation) เท่ากับ 862.77 วินาที จึงได้

$\bar{T}_{investigation} = \frac{862.77}{9} = 95.86$ วินาที ค่ามัธยฐาน 77.77 วินาที ค่าต่ำสุด 47.10 วินาที และค่าสูงสุด 243.43 วินาที ส่วนเบี่ยงเบนมาตรฐานคำนวณแบบตัวอย่างจาก

$$SD = \sqrt{\frac{1}{n-1} \sum_{i=1}^n (T_{investigation,i} - \bar{T}_{investigation})^2} = 58.87\ s \quad (19)$$

ค่าที่สูงใน TC-03 เกิดจากการเรียกสร้าง Recommendation 3 ครั้ง (ไม่ผ่านการตรวจสอบ 2 ครั้ง) และ Analyst Intervention 1 ครั้ง

4.2.8 Decision Recording Latency

$$T_{decision} = T_{IR\ decision} - T_{recommendation} \quad (20)$$

$$\bar{T}_{decision} = \frac{1}{n} \sum_{i=1}^n T_{decision,i} \quad (21)$$

ค่าเฉลี่ยจาก 9 กรณีอยู่ที่ประมาณ 0.06 วินาที (ค่าที่บันทึกมีทศนิยม 2 ตำแหน่ง อยู่ในช่วง 0.05–0.06 วินาทีต่อกรณี) เนื่องจากใช้ Scripted Approval คำนี้อาจสะท้อนเวลาที่ระบบใช้บันทึกการตัดสินใจ ไม่ใช่เวลาที่ผู้ปฏิบัติงานใช้วิเคราะห์และตัดสินใจ

4.2.9 Intervention Rate

$$IR = \frac{N_{intervention}}{N_{evaluated}} \times 100 \quad (22)$$

พบ Analyst Intervention ใน TC-03 และ TC-05 (ทั้งสองกรณีเป็นการยกระดับสถานะของ IOC ที่สกัดได้ ไม่ใช่การแก้ไข Recommendation) จึงได้ $IR = \frac{2}{10} \times 100 = 20.00\%$

4.2.10 Retry Rate และ Retry Count

$$RR = \frac{N_{cases\ with\ retry}}{N_{evaluated}} \times 100 \quad (23)$$

$$Retry\ Count = \sum_{i=1}^n R\ retry_i \quad (24)$$

TC-03 และ TC-05 เป็นกรณีที่ ต้องเรียกสร้าง Recommendation ซ้ำ จึงได้ $RR = \frac{2}{10} \times 100 = 20.00\%$ และเนื่องจากการเรียกสร้างที่ไม่ผ่านการตรวจสอบรวม 7 ครั้ง

ตารางที่ 4.2 ผลการทดลองรายการณ์

Case	Compliance	Workflow	Verification	IOC Recall	Calls (ล้มเหลว)	Interv.	Inv. Time (s)	Correct Rec.
TC-01	COMPLIANT	Complete	RESOLVED	2/2	1 (0)	0	54.74	ตรง
TC-02	COMPLIANT	Incomplete	ตรวจสอบไม่ได้*	0/2	1 (0)	0	75.44	ไม่ตรง
TC-03	COMPLIANT	Complete	RESOLVED	4/4	3 (2)	1	243.43	ตรง
TC-04	COMPLIANT	Complete	RESOLVED	2/2	1 (0)	0	93.32	ไม่ตรง
TC-05	NOT_EVALUATED	Incomplete	—	1/1	5 (5)	1	—	ไม่มี Rec.
TC-06	COMPLIANT	Complete	RESOLVED	1/1	1 (0)	0	47.10	ตรง
TC-07	COMPLIANT	Complete	RESOLVED	3/3	1 (0)	0	83.99	ไม่ตรง
TC-08	COMPLIANT	Complete	RESOLVED	4/4	1 (0)	0	115.56	ตรง
TC-09	COMPLIANT	Complete	RESOLVED	3/3	1 (0)	0	77.77	ไม่ตรง
TC-10	COMPLIANT	Incomplete	ตรวจสอบไม่ได้*	1/1	1 (0)	0	71.42	ไม่ตรง

REHUNT_INSUFFICIENT_CRITERIA หมายถึงมีข้อมูลไม่เพียงพอสำหรับสร้างเงื่อนไข Re-hunt และไม่ใช่สถานะ NOT_RESOLVED ส่วน TC-05 ไม่มี Recommendation ที่ผ่านการตรวจสอบ จึงไม่มีผล

(TC-03 2 ครั้ง, TC-05 5 ครั้ง) จึงได้ $Retry\ Count = 7$ กล่าวคือ Retry Rate วัดสัดส่วนกรณีที่เกิด Retry อย่างน้อยหนึ่งครั้ง ขณะที่ Retry Count วัดจำนวนครั้งที่เกิดจริง

4.2.11 Escalation Rate

$$ER = \frac{N_{escalated}}{N_{rehunt}} \times 100 \quad (25)$$

ไม่พบกรณีที่เข้าสู่สถานะ ESCALATED จากกรณีที่ดำเนิน Re-hunt 7 กรณี ($N_{rehunt} = 7$) จึงได้ $ER = \frac{0}{7} \times 100 = 0\%$ เนื่องจากทุก Re-hunt จบด้วย RESOLVED ในรอบแรก จึงไม่เข้าเงื่อนไขของ Escalation ผลนี้จึงไม่ใช่การยืนยันประสิทธิภาพของกลไก Escalation ซึ่งทดสอบแยกในการทดลองเสริม (หัวข้อ 4.6)

4.3 ผลการทดลอง

4.3.1 ผลการทดลองรายการณ์

ผลการทดลองรายการณ์แสดงในตารางที่ 4.2 โดยพิจารณา Recommendation Compliance, Correct Recommendation, Workflow, Verification/Re-hunt, IOC Recall, จำนวนครั้งที่เรียกสร้าง Recommendation, Intervention และ Investigation Time

Compliance (NOT_EVALUATED) และนับเป็นกรณีที่ผิดตรง Ground Truth "ไม่ตรง" ของ TC-04, TC-07, TC-09 และ TC-10 หมายถึงมี Action ที่จำเป็นครบแต่เสนอ Action เพิ่มเติมนอกชุด Ground Truth ส่วน TC-02 ขาด Action

ที่จำเป็น

TC-01, TC-03, TC-04, TC-06, TC-07, TC-08 และ TC-09 ดำเนิน Workflow จนถึง Verification/Re-hunt และได้ผล RESOLVED ส่วน TC-02 และ TC-10 ไม่สามารถตรวจสอบซ้ำได้เนื่องจาก IOC ไม่เพียงพอสำหรับสร้างเงื่อนไขค้นหา และ TC-05 หยุดที่ชั้น Recommendation TC-03 ใช้เวลาสูงสุด เนื่องจาก Recommendation ไม่ผ่าน Validation ใน 2 ครั้งแรก ผ่านในครั้งที่ 3 และมีการปรับ IOC โดย Analyst 1 ครั้ง

4.3.2 ผลการประเมินตัวชี้วัดรวม

ตารางที่ 4.3 ผลการประเมินตัวชี้วัดของระบบ VIGIX

Metric	ผล	ตัวตั้ง/ตัวหาร	หมายเหตุ
Correct Recommendation (ตัวชี้วัดหลัก)	40.00%	4/10	strict exact-match; TC-05 นับว่าไม่มี Recommendation
Recommendation Compliance	100%	9/9	7 เกณฑ์; เฉพาะกรณีที่ Recommendation (TC-05 NOT_EVALUATED); ไม่ใช้ความแม่นยำ
First-pass (call แรกผ่าน validator)	80.00%	8/10	TC-03, TC-05 ไม่ผ่านใน call แรก
Workflow Completion	70.00%	7/10	TC-02, TC-05, TC-10 ไม่ครบ
Verification / Re-hunt	70.00%	7/10	ผลบน Wazuh จริง
IOC Recall	91.30%	21/23	ก่อนแก้โดย analyst
Investigation Time	mean 95.86 s	n = 9	median 77.77, min 47.10, max 243.43, SD 58.87
Decision Recording Latency	≈ 0.06 s	n = 9	scripted approval (0.05–0.06 s ต่อกรณี)
Intervention Rate	20.00%	2/10	TC-03, TC-05 (ยกระดับ IOC)
Retry Rate	20.00%	2/10	รวม 7 ครั้ง (TC-03 2, TC-05 5) จาก 16 calls

Metric	ผล	ตัวตั้ง/ตัวหาร	หมายเหตุ
Escalation Rate	0%	0/7	ไม่ได้เกิดเงื่อนไข; ทดสอบแยกในหัวข้อ 4.6
Infrastructure Failure	0	0/10	ไม่มี

ผลการทดลองในตารางที่ 4.3 แสดงว่า Recommendation ตรงกับ Ground Truth ทั้งหมด 4 จาก 10 กรณี (ร้อยละ 40.00) ขณะที่ Recommendation Compliance ผ่านทุกกรณีที่ Recommendation (9 จาก 9) ซึ่งเป็นตัวชี้วัดคนละชนิดและไม่ใช้ความแม่นยำ Workflow Completion และ Verification/Re-hunt อยู่ที่ 70.00% โดยกรณีที่ไม่มีสมบรูณ์มาจาก Evidence และ IOC ที่ไม่เพียงพอสำหรับ Re-hunt (TC-02, TC-10) และการที่ระบบสร้าง Recommendation ที่ผ่านการตรวจสอบไม่ได้ (TC-05) ค่าเฉลี่ย Investigation Time (95.86 s) สูงกว่าค่ามัธยฐาน (77.77 s) เนื่องจากอิทธิพลของ TC-03 ซึ่งต้องเรียกสร้าง Recommendation ซ้ำ

4.4 การควบคุม Human-in-the-Loop

VIGIX กำหนดให้ระบบทำหน้าที่สร้าง Recommendation และสนับสนุนการวิเคราะห์เท่านั้น โดยไม่สามารถอนุมัติหรือดำเนินการ Response ได้เอง ผลการตรวจสอบการควบคุมแสดงในตารางที่ 4.4

ตารางที่ 4.4 ผลการตรวจสอบการควบคุม Human-in-the-Loop

การควบคุม	ผล
Severity ได้จาก Wazuh ไม่ได้กำหนดโดย AI	PASS
ไม่มี Response ที่ถูกดำเนินการโดยไม่ผ่านการอนุมัติของ IR	PASS
ไม่มี Incident ที่ถูกปิดโดย AI	PASS
IR decision ถูกบันทึกในทุกเคสที่มี Recommendation (9 จาก 9)	PASS
เมื่อ IR ปฏิเสธ Recommendation ไม่มีการดำเนินการอัตโนมัติ ไม่ปิด Incident และไม่สร้าง Recommendation ใหม่ (การทดลองเสริม TC-01, การตัดสินใจแบบสคริปต์)	PASS

ผลการตรวจสอบในตารางที่ 4.4 ยืนยันว่าในสถานการณ์ที่ทดสอบ การตัดสินใจดำเนินการ Response อยู่ในขั้นตอนของ IR และการทดลองเสริมเรื่องการปฏิเสธโดย IR (หัวข้อ 4.6) ให้ผล

สอดคล้องกัน อย่างไรก็ตาม เนื่องจากใช้ Scripted Approval ผลนี้จึงเป็นการตรวจสอบกลไกของระบบ ไม่ใช่การประเมินพฤติกรรมหรือความถูกต้องในการตัดสินใจของผู้ปฏิบัติงานจริง ตารางที่ 4.5 ข้อสังเกตจากการทดลอง

Case	ข้อสังเกต	สาเหตุ	ผลกระทบ
TC-02	ไม่ได้ IOC hash/file path (Recall 0/2)	หลักฐานอยู่ใน syscheck.* แต่ตัวตั้ง IOC อ่านเฉพาะ data.*	ไม่มีเกณฑ์ค้นหาซ้ำ จึง Verify ไม่ได้
TC-03	ต้องเรียกสร้าง Recommendation 3 ครั้ง และ analyst promote IOC	2 ครั้งแรกไม่ผ่าน validation (INVENTED_TARGET, TARGET_TYPE_MISMATCH); IOC ยังไม่ถูกยกระดับให้เป็น target	เวลา 243.43 s (สูงสุด); นับเป็น intervention
TC-05	ไม่มี Recommendation ที่ผ่าน validator (5 calls)	LLM เสนอ Target ที่ไม่มี Evidence (INVENTED_TARGET) และ Action ที่ขาดหลักฐาน (INSUFFICIENT_EVIDENCE) ตามขั้นตอนของ Playbook; Evidence ของ scenario มีเฉพาะ domain	Workflow หยุดที่ขั้น Recommendation; นับเป็นไม่ตรง GT
TC-10	IOC เป็น USERNAME อย่างเดียว	ค้นหาข้าม Wazuh ด้วย USERNAME ไม่ได้ และไม่มี IP/Domain/URL/Hash	Verify ไม่ได้
TC-04, 07, 09, 10	มี Action เพิ่มเติมนอกชุด Ground Truth (REVOKE-SESSION, BLOCK-URL, ISOLATE-ENDPOINT)	Action ส่วนใหญ่อยู่ใน Playbook (allowedActions หรือขั้นตอน unconditional) แต่ Ground Truth ไม่ได้กำหนดเป็นคู่ที่คาดหวัง	นับเป็นไม่ตรง GT ทั้งที่มี Action ที่จำเป็นครบ

จากตารางที่ 4.5 พบว่าข้อจำกัดเกี่ยวข้องกับ (1) ความครอบคลุมของ Evidence และ IOC Extraction โดยเฉพาะข้อมูลในโครงสร้าง syscheck.* และ IOC ประเภท USERNAME (2) การที่ LLM เสนอ Target หรือ Action ที่ไม่มี Evidence รองรับ จนต้องสร้างซ้ำ (TC-03) หรือสร้างไม่สำเร็จ (TC-05) และ (3) ความไม่ตรงระหว่าง Action ที่ Playbook อนุญาตกับชุด Action ที่ Ground Truth กำหนด ซึ่งทำให้ TC-04, TC-07, TC-09 และ TC-10 ไม่ตรง Ground Truth แม้มี Action ที่จำเป็นครบ จากการวิเคราะห์ภายหลัง (post-hoc ซึ่งยังไม่ผ่านการตรวจสอบโดยผู้เชี่ยวชาญ) Action เพิ่มเติม 6 คู่ มีหลักฐาน Playbook และ Policy รองรับ 4 คู่ และรองรับบางส่วน 2 คู่ ดังนั้นค่า 40.00% ไม่ควรตีความเป็นความแม่นยำของ AI โดยรวม

ข้อจำกัดของการทดลองประกอบด้วยจำนวนกรณีทดสอบที่จำกัด (10 กรณี รัน 1 ครั้ง ไม่มีช่วงความเชื่อมั่น) การใช้ LLM เพียงหนึ่งแบบจำลอง การใช้ข้อมูลจากสถานการณ์ที่ควบคุมในห้องปฏิบัติการ และการอนุมัติของ IR แบบสคริปต์ นอกจากนี้ Ground Truth กำหนดโดยผู้พัฒนาและปรับหลังเห็นผลรุ่นก่อน ไม่มีผู้เชี่ยวชาญอิสระตรวจสอบ กรณี PowerShell ใช้กฎที่พัฒนาเพิ่มและกิจกรรมที่ผู้ทดลองเป็นผู้กระตุ้นบน endpoint เพียงเครื่องเดียว Consistency ทดสอบบนหลักฐานชุดเดิม

4.5 ข้อสังเกตและข้อจำกัด

ข้อสังเกตสำคัญจากกรณีทดสอบแสดงในตารางที่ 4.5

เฉพาะ 3 กรณี และการทดลอง Escalation กับการปฏิเสธโดย IR ทดสอบอย่างละหนึ่ง scenario ดังนั้นผลการทดลองยังไม่สามารถสรุปประสิทธิภาพของระบบในสภาพแวดล้อม SOC จริงได้

4.6 การทดลองเสริม (รายงานแยกจากผลหลัก)

การทดลองเสริมด้าน Escalation ($R_{max} = 3$) ใช้ telemetry ของ TC-07 และทำซ้ำการโจมตีหลัง Response แต่ละรอบ ผลคือ Re-hunt บน Wazuh ได้ NOT_RESOLVED ทั้ง 3 รอบ (พบเหตุการณ์ที่เกี่ยวข้องรอบละ 3 รายการ) Incident เปลี่ยนสถานะเป็น ESCALATED ด้วยเหตุผล MAX_INVESTIGATION_ROUNDS_REACHED และไม่มีรอบที่ 4 โดยการตรวจสอบของ runner ผ่านครบ 15 จาก 15 รายการในรอบที่ 2 และ 3 ระบบสร้าง Recommendation ใหม่ไม่ได้ (NO_NEW_RECOMMENDATION) runner จึงใช้ขั้นตอนเดิมจาก Recommendation แรกส่งให้ IR การสร้าง recurrence ทำโดย runner ส่วนการตัดสินใจ NOT_RESOLVED การเปิดรอบใหม่ และ ESCALATED เป็นของระบบ การทดลองเสริมด้านการปฏิเสธโดย IR ใช้ TC-01 โดยให้สคริปต์ในบทบาท IR ปฏิเสธ Recommendation ผลคือไม่มีการดำเนินการตอบสนองหลังการปฏิเสธ คำสั่งเริ่ม Response ถูกปฏิเสธ Incident ไม่ถูกปิด ไม่มีการสร้าง Recommendation

ใหม่ การตัดสินใจและหมายเหตุถูกบันทึกพร้อมร่องรอยตรวจสอบ และ SOC, AI_AGENT และ admin ไม่สามารถอนุมัติแทน IR_TEAM (ผ่านการตรวจ 12 จาก 12 รายการ) หลังการปฏิเสธ IR บันทึก Manual Decision พร้อมหมายเหตุ ดำเนิน Manual Response แบบจำลอง และเข้าสู่ Re-hunt ได้ตามที่ออกแบบ การทดลองนี้ใช้การตัดสินใจแบบสคริปต์ จึงประเมินพฤติกรรมของระบบ ไม่ใช่คุณภาพหรือเวลาการตัดสินใจของผู้ปฏิบัติงาน

5.สรุปผลการทดลอง

งานนี้มีวัตถุประสงค์เพื่อพัฒนา VIGIX ให้เป็นแพลตฟอร์มสำหรับสนับสนุนการปฏิบัติงานของ Security Operations Center (SOC) โดยเชื่อมโยงการรับ Security Alert การรวบรวมและวิเคราะห์ Evidence การสร้าง Recommendation การตัดสินใจของผู้ปฏิบัติงาน การ Response และการตรวจสอบผลด้วย Re-hunt ภายใต้แนวคิด Human-in-the-Loop ระบบไม่ได้ดำเนินการ Response หรือปิด Incident โดยอัตโนมัติ แต่ให้ผู้ปฏิบัติงานเป็นผู้ตัดสินใจในขั้นตอนสำคัญ

จากการทดลอง Final Evaluation ด้วย Wazuh จริงจำนวน 10 กรณี พบว่า Recommendation ตรงกับ Ground Truth ทั้งชุดภายใต้เกณฑ์ strict exact-match 4 จาก 10 กรณี (ร้อยละ 40.00) กรณีที่ไม่ตรงส่วนใหญ่มี Action ที่จำเป็นครบแต่เสนอ Action เพิ่มเติมนอกชุดอ้างอิง หนึ่งกรณีเสนอ Action ที่จำเป็นไม่ครบ และกรณี PowerShell ไม่สามารถสร้าง Recommendation ที่ผ่านการตรวจสอบของระบบได้ ขณะที่ Recommendation Compliance ผ่านทุกกรณีที่ประเมินได้ (9 จาก 9) ซึ่งวัดการปฏิบัติตามกฎของระบบ ไม่ใช่ความถูกต้องของคำแนะนำ กระบวนการตั้งแต่ Recommendation จนถึง Verification/Re-hunt ดำเนินการครบ 7 จาก 10 กรณี (ร้อยละ 70.00) และ IOC Recall อยู่ที่ร้อยละ 91.30 ประสิทธิภาพของขั้น Verification ยังขึ้นอยู่กับรูปแบบ Evidence และประเภท IOC ที่ระบบสามารถนำไปใช้ค้นหาซ้ำได้ ส่วนการทดลองเสริมชี้ว่า Playbook และ Target ของแต่ละ Action คงที่เมื่อสร้างซ้ำ แต่ชุด Action ผันแปร (Core Consistency ร้อยละ 75.00) และกลไก Escalation กับการปฏิเสธโดย IR ทำงานตามที่ออกแบบใน scenario ที่ทดสอบ

การทดลองยังพบข้อจำกัดจากโครงสร้างข้อมูลของ Wazuh และความแตกต่างของ IOC แต่ละประเภท ความไม่ตรงระหว่าง Action ที่ Playbook อนุญาตกับชุด Action อ้างอิงของ Ground Truth รวมถึงกรณีที่ LLM ต้องสร้างซ้ำหรือสร้าง Recommendation ที่ผ่านการตรวจสอบไม่ได้ ซึ่งสะท้อนความจำเป็นของกลไกตรวจสอบผลลัพธ์ก่อนนำไปใช้จริง นอกจากนี้ การทดลองอยู่ในสภาพแวดล้อมที่ควบคุม ใช้ LLM เพียงหนึ่งโมเดล และการอนุมัติของ IR เป็นแบบสคริปต์ จึงยังไม่สามารถสรุปประสิทธิภาพของระบบในสภาพแวดล้อม SOC จริงได้ โดยสรุป ในสถานการณ์ที่ทดสอบ VIGIX สามารถสนับสนุน Workflow ของ SOC และ IR ตั้งแต่ Alert ถึง Verification ได้ตามขอบเขตที่กำหนด และช่วยจัด Recommendation ให้อยู่ภายใต้การตัดสินใจของผู้ปฏิบัติงาน อย่างไรก็ตาม ความตรงของ Recommendation กับ Ground Truth อยู่ที่ร้อยละ 40.00 และความสามารถของระบบยังขึ้นอยู่กับคุณภาพและโครงสร้างของ Evidence รวมถึงความสามารถในการนำ IOC ไปใช้ Re-hunt ดังนั้นการพัฒนาต่อไปควรให้ผู้เชี่ยวชาญอิสระทบทวน Playbook และ Ground Truth ขยายสถานการณ์และจำนวนโมเดลที่ทดลอง และประเมินระบบร่วมกับ SOC/IR Analyst จริงเพื่อวัดการใช้งานในสภาพแวดล้อมที่ใกล้เคียงการปฏิบัติงานจริงมากขึ้น

การเปิดเผยการใช้ปัญญาประดิษฐ์และข้อมูล

การใช้ปัญญาประดิษฐ์เชิงสร้างสรรค์ (GenAI) ในการจัดทำงานนี้: [ผู้เขียนระบุเครื่องมือ ผู้ให้บริการ โมเดลและเวอร์ชัน ขั้นตอนที่ใช้ เช่น การเขียนโค้ด การวิเคราะห์ผล การเรียบเรียง และการตรวจสอบผลลัพธ์โดยผู้เขียน โดยเขียนจากบันทึกที่เกิดขึ้นจริง] ข้อมูลและสิทธิ์การใช้: สถานการณ์โจมตีทั้งหมดจำลองในห้องปฏิบัติการ [ผู้เขียนยืนยัน: ไม่ได้ใช้ข้อมูลจริงขององค์กร] ส่วน Policy, Playbook และ Runbook ที่ใช้ [ระบุ: สร้างขึ้นเพื่อการทดลอง หรือได้รับอนุญาตจากองค์กร] แบบจำลองภาษา vllm-spark-01/gemma4-26b-uncensored ให้บริการที่ [ระบุเครื่องมือให้บริการและเจ้าของ] [ผู้เขียนยืนยันว่าข้อมูลของระบบไม่ถูกส่งไปยังบริการภายนอกที่ไม่ได้รับอนุญาต]

หลักฐานการทดลอง: run ID final-evaluation-v3.3 (source commit 245b536, Ground Truth correctness-gt-v3.3) และการทดลองเสริม supplementary-consistency-15r,

supp-escalation-20261003 และ supplementary-ir-reject จัดเก็บในที่เก็บ GitHub ของโครงการ

([https://github.com/kanokniphanset/VIGIX-AI-](https://github.com/kanokniphanset/VIGIX-AI-Powered-SOC-Automation-Platform)

Powered-SOC-Automation-Platform, source commit

245b536 และไฟล์เตอร์ results/runs) ผู้ตรวจสอบสามารถขอ

เข้าถึงหรือขอตรวจสอบหลักฐานได้จากผู้เขียนที่ [อีเมลผู้เขียน]

เอกสารอ้างอิง

[1] R. Ismail, K. R. Kurnia, F. Widyatama, I. M. Wibawa, Z. A. Brata, Ukasyah, G. A. Nelistiani, and H. Kim, “Enhancing security operations center: Wazuh security event response with retrieval-augmented-generation-driven copilot,” **Sensors**, vol. 25, no. 3, Art. no. 870, 2025, doi: 10.3390/s25030870.

[2] S. Barbieri, L. Vaz de Meneses, Á. L. R. Ferraz, and L. A. Pereira Júnior, “SOCpilot: Verifying policy compliance for LLM-assisted incident response,” **arXiv preprint arXiv:2605.05501**, 2026, doi: 10.48550/arXiv.2605.05501.

[3] A. Tellache, A. A. Korba, A. Mokhtari, H. Moldovan, and Y. Ghamri-Doudane, “Advancing autonomous incident response: Leveraging LLMs and cyber threat intelligence,” in **Proc. IEEE Global Communications Conference (GLOBECOM)**, 2025.

[4] Z. Liu and A. Anwar, “AutoBnB-RAG: Enhancing multi-agent incident response with retrieval-augmented generation,” in **Proc. 2025 IEEE International Conference on Data Mining Workshops (ICDMW)**, pp. 1190–1199, 2025.

[5] R. Singh, S. Tariq, F. Jalalvand, M. B. Chhetri, S. Nepal, C. Paris, and M. Lochner, “LLMs in the SOC: An empirical study of human-AI collaboration in security operations centres,” **arXiv preprint arXiv:2508.18947**, 2025.

[6] S. Sheikhi, P. Kostakos, and L. Lovén, “Cognitive SOC: Evidence-backed narrative generation for security operations with multi-agent LLM architecture,” in **Proc. 2025 IEEE International Conference on Big Data*

(BigData)*, Macau, China, 2025, pp. 7027–7036, doi: 10.1109/BigData66926.2025.11401968.

[7] M. Rieger, A. Shah, A. Alam, and M. J. Hossain, “Possibilities and limitations of using large language models (LLMs) for alert classification and prioritisation in security operations centers (SOCs),” **Expert Systems with Applications**, vol. 331, Part C, Art. no. 133194, 2026, doi: 10.1016/j.eswa.2026.133194.

[8] A. Nelson, S. Rekhi, M. Souppaya, and K. Scarfone, “Incident response recommendations and considerations for cybersecurity risk management: A CSF 2.0 community profile,” NIST, Gaithersburg, MD, USA, NIST SP 800-61 Rev. 3, Apr. 2025, doi: 10.6028/NIST.SP.800-61r3.

[9] SANS Institute, “Incident Management 101: Preparation and Initial Response (aka Identification),” SANS Institute InfoSec Reading Room, 2005.